



ARKA HEALTH, INC.

INFORMATION SECURITY & COMPLIANCE PROGRAM CHARTER

Establishing the privacy, security, and compliance program of ARKA Health, Inc.

ARKA-GOV-001 · Version 1.0 · Confidential — Internal

Document No.	ARKA-GOV-001
Version	1.0
Effective Date	June 10, 2026
Last Reviewed	June 10, 2026
Document Owner	Arri Kanna, Founder & Chief Executive Officer — Privacy & Security Officer
Approved By	Arri Kanna, Founder & Chief Executive Officer
Classification	Confidential — Internal
Review Cycle	Annual, and upon any material change in operations, systems, or law

This document contains confidential and proprietary information of ARKA Health, Inc. (“ARKA”). It is furnished for informational and compliance purposes, may not be reproduced or disclosed to any third party without the prior written consent of ARKA, and must be returned or destroyed upon request. Nothing in this document constitutes legal advice.

1. PURPOSE AND AUTHORITY

This Information Security & Compliance Program Charter (this “**Charter**”) establishes the information privacy, information security, and regulatory compliance program (the “**Program**”) of ARKA Health, Inc., a Delaware corporation (“**ARKA**” or the “**Company**”). This Charter is adopted under the authority of the Company’s Board of Directors and Chief Executive Officer and constitutes the governing instrument from which each policy, plan, standard, and procedure enumerated in Section 6 derives its authority.

The Program is designed to satisfy, and to generate auditable evidence of conformity with: (i) the administrative simplification provisions of the Health Insurance Portability and Accountability Act of 1996, as amended by the Health Information Technology for Economic and Clinical Health Act (“**HITECH**”) and their implementing regulations at 45 C.F.R. Parts 160 and 164, including the Privacy Rule, the Security Rule, and the Breach Notification Rule (collectively, “**HIPAA**”); (ii) the Trust Services Criteria promulgated by the American Institute of Certified Public Accountants (“**AICPA**”) for SOC 2® examinations (Security, Availability, and Confidentiality categories); (iii) the HITRUST CSF® as scoped for the HITRUST Essentials, 1-Year (e1) Validated Assessment; and (iv) applicable state privacy and data-security statutes.

2. SCOPE

This Charter applies to: (a) all officers, directors, employees, and individual independent contractors of the Company (collectively, “**Workforce Members**”); (b) all information systems, applications, infrastructure, and services owned, licensed, or operated by or on behalf of the Company, including the ARKA clinical decision-support and administrative-workflow platform and its constituent modules (ARKA-CLIN, ARKA-ED, ARKA-INS, and ARKA-RURAL) (the “**ARKA Platform**”); and (c) all information created, received, maintained, processed, or transmitted by the Company, in any form or medium, including electronic Protected Health Information (“**ePHI**”) as defined at 45 C.F.R. § 160.103.

Status acknowledgment. As of the Effective Date, the Company operates in a pre-commercial validation posture: the publicly accessible ARKA demonstration environment processes **synthetic data only and no Protected Health Information**, as documented in ARKA-DEMO-001. The policies constituting the Program are nonetheless adopted as presently binding obligations so that required safeguards, documentation, and evidence exist **before** the first engagement in which the Company creates, receives, maintains, or transmits PHI in its capacity as a business associate.

3. DESIGNATION OF RESPONSIBLE OFFICIALS

Pursuant to 45 C.F.R. § 164.530(a)(1) and § 164.308(a)(2), the Company hereby designates:

Role	Designee	Authority
HIPAA Privacy Officer	Arri Kanna, Founder & Chief Executive Officer	Development and implementation of privacy policies; receipt of complaints; privacy training; individual-rights administration.
HIPAA Security Officer	Arri Kanna, Founder & Chief Executive Officer	Development and implementation of the safeguards required by the Security Rule; risk analysis; incident response command.

Role	Designee	Authority
Compliance Contact	privacy@getarka.health / security@getarka.health	Designated channels for privacy and security inquiries, complaints, and vulnerability reports.

One individual may hold both officer designations while the Company employs fewer than twenty-five (25) Workforce Members. Upon exceeding that threshold, or upon execution of the Company’s third business associate agreement with a covered entity, whichever occurs first, the Board shall evaluate separation of the roles and the engagement of a virtual or fractional Chief Information Security Officer.

4. GOVERNANCE STRUCTURE

4.1 Security & Compliance Committee

A Security & Compliance Committee (the “**Committee**”) is hereby constituted, consisting of the Privacy Officer, the Security Officer, and, as the Company scales, the engineering lead and one independent advisor. Until additional members are appointed, the designated officer shall discharge Committee functions and shall document each quarterly review in written minutes. The Committee shall: (a) review risk-analysis results and approve the annual risk-management plan; (b) approve, ratify, and retire policies; (c) review security incidents, sanction determinations, and corrective-action plans; (d) monitor third-party audit and certification milestones against ARKA-RDY-004; and (e) report to the Board no less than semi-annually.

4.2 Policy lifecycle and document control

1. **Adoption.** A policy becomes effective upon written approval by the designated officer recorded in the document’s Adoption and Approval block.
2. **Review.** Each policy shall be reviewed at least annually, and within thirty (30) days following any material change in operations, architecture, vendors, or applicable law, in accordance with the evaluation standard at 45 C.F.R. § 164.308(a)(8).
3. **Versioning.** Documents follow semantic versioning (major.minor). Material amendments increment the major version and require re-approval; editorial corrections increment the minor version.
4. **Retention.** Pursuant to 45 C.F.R. § 164.316(b)(2)(i), each policy, and each required action, activity, or assessment documented under the Program, shall be retained for a minimum of six (6) years from the later of its creation date or the date it was last in effect.
5. **Availability.** Current policies shall be made available to all Workforce Members and, upon execution of appropriate confidentiality undertakings, to customers, prospective customers, and auditors conducting security diligence.

5. REGULATORY FRAMEWORK AND PROGRAM COMMITMENTS

5.1 HIPAA

When ARKA creates, receives, maintains, or transmits PHI on behalf of a covered entity or another business associate, ARKA will do so solely pursuant to an executed business associate agreement substantially in the form of ARKA-LGL-001, and will comply with the Security Rule in full and with the Privacy Rule

provisions applicable to business associates, including the prohibitions on uses and disclosures not permitted by the agreement, the minimum-necessary standard, and the breach-notification obligations of 45 C.F.R. §§ 164.410 and 164.412.

5.2 Heightened baseline — 2025 Security Rule rulemaking

In December 2024, the U.S. Department of Health and Human Services, Office for Civil Rights, issued a notice of proposed rulemaking to strengthen the Security Rule (90 Fed. Reg. 898, Jan. 6, 2025). The Company has elected to adopt the principal proposed specifications as its internal baseline notwithstanding that a final rule may not yet be effective, including: removal of reliance on “addressable” designations; mandatory multi-factor authentication; mandatory encryption of ePHI at rest and in transit; maintenance of a technology asset inventory and network map; vulnerability scanning at least every six (6) months and annual penetration testing; network segmentation; and demonstrated capability to restore critical systems within seventy-two (72) hours. These commitments are implemented through the ARKA-SEC policy series.

5.3 SOC 2 and HITRUST

The Company maintains a SOC 2 readiness program (ARKA-RDY-002) targeting a Type I examination followed by a Type II examination covering the Security, Availability, and Confidentiality categories, and a HITRUST e1 readiness program (ARKA-RDY-003). The Company **does not represent that it is SOC 2 attested or HITRUST certified** and shall not so represent until the applicable report or certification has been issued; external communications shall describe these efforts as “in progress” or “audit-ready,” consistent with ARKA-RDY-004.

5.4 Relationship to FDA regulatory posture

The Company’s position regarding FDA oversight of its software functions (Non-Device CDS analysis under section 520(o)(1)(E) of the FD&C Act) is maintained separately in the Company’s regulatory documentation and Trust Center. This Charter governs privacy and security; nothing herein shall be construed as a representation regarding FDA clearance, approval, or concurrence.

6. POLICY FRAMEWORK

The Program comprises the following controlled documents, each of which is incorporated into this Charter by reference:

Document No.	Title
ARKA-GOV-001	Information Security & Compliance Program Charter
ARKA-PRIV-001	HIPAA Privacy Policy
ARKA-PRIV-002	De-Identification & Limited Data Set Policy
ARKA-LGL-001	Business Associate Agreement (Template)
ARKA-SEC-001	Information Security Policy
ARKA-SEC-002	Risk Analysis & Risk Management Policy
ARKA-SEC-003	Access Control & Identity Management Policy
ARKA-SEC-004	Encryption & Key Management Policy

Document No.	Title
ARKA-SEC-005	Audit Logging & Monitoring Policy
ARKA-SEC-006	Security Incident Response & Breach Notification Plan
ARKA-SEC-007	Contingency Plan: Data Backup, Disaster Recovery & Emergency Mode Operations
ARKA-SEC-008	Workforce Security Training & Sanction Policy
ARKA-SEC-009	Vendor & Subcontractor Risk Management Policy
ARKA-SEC-010	Secure Software Development & Change Management Policy
ARKA-SEC-011	Data Classification, Retention & Secure Disposal Policy
ARKA-SEC-012	Acceptable Use, Workstation & Mobile Device Policy
ARKA-RDY-001	HIPAA Security Risk Assessment Report (2026)
ARKA-RDY-002	SOC 2 Readiness & Gap Assessment
ARKA-RDY-003	HITRUST e1 Readiness Roadmap
ARKA-RDY-004	Compliance Roadmap & Certification Timeline
ARKA-DEMO-001	Demonstration Environment Synthetic Data Policy & No-PHI Attestation

7. ENFORCEMENT, EXCEPTIONS, AND NON-RETALIATION

Violations of the Program are subject to the graduated sanctions set forth in ARKA-SEC-008, up to and including termination of employment or engagement. Any exception to a Program requirement must be requested in writing, must identify compensating controls, and may be granted only by the Security Officer for a defined period not to exceed ninety (90) days, subject to renewal upon re-evaluation; all exceptions shall be recorded in the exception register. The Company shall not intimidate, threaten, coerce, discriminate against, or take other retaliatory action against any individual for filing a complaint, reporting a suspected incident in good faith, or participating in any investigation or proceeding, consistent with 45 C.F.R. § 160.316.

8. NO THIRD-PARTY RIGHTS; NO LEGAL ADVICE

This Charter is an internal governance instrument. It does not create contractual rights in favor of any third party, is not a representation or warranty to any customer except to the extent expressly incorporated into a written agreement signed by the Company, and does not constitute legal advice. In the event of a conflict between this Charter and an executed business associate agreement, the executed agreement controls with respect to the parties thereto.

DOCUMENT CONTROL & REVISION HISTORY

Version	Date	Author / Reviewer	Description of Change
0.9	May 22, 2026	A. Kanna (drafting); external review pending	Initial draft circulated for internal review and counsel comment.

Version	Date	Author / Reviewer	Description of Change
1.0	June 10, 2026	A. Kanna, Privacy & Security Officer	Adopted as effective policy of ARKA Health, Inc. by written approval of the undersigned officer.

ADOPTION AND APPROVAL

The undersigned, being the duly designated Privacy Officer and Security Officer of ARKA Health, Inc., hereby adopts this document as an official policy of the Company, effective as of the Effective Date set forth on the cover page hereof. This document shall be reviewed no less frequently than annually and upon any material change to the Company's operations, information systems, or applicable law, and may be amended only in accordance with ARKA-GOV-001 (Information Security & Compliance Program Charter).

ARKA HEALTH, INC.

By: _____

Name: Arri Kanna

Title: Founder & Chief Executive Officer; Privacy & Security Officer

Date: June 10, 2026